

BTS SIO – Services Informatiques aux Organisations

Option SISR – Solutions d'Infrastructure, Systèmes et Réseaux

Épreuve U6 – Parcours de Professionnalisation

Déploiement d'une solution SIEM/XDR

Wazuh – Supervision et Détection des Intrusions

Mission réalisée pour la société CUB (Incubateur de startups)

Étudiant : GRECH Mattéo

Entreprise : Securitech

Établissement : ESICAD – Montpellier

Année scolaire : 2025-2026

Sommaire

Section	Page
1. Introduction	3
2. Présentation du projet	4
3. Pourquoi avoir choisi Wazuh	5
4. Présentation de l'infrastructure	6

5. Prérequis techniques	7
6. Installation de Wazuh	8
7. Configuration de Wazuh	10
8. Durcissement SCA (Hardening)	11
9. Tests réalisés – Attaque Hydra	13
10. Résultats obtenus	15
11. Difficultés rencontrées	16
12. Documentation utilisée	17
13. Conclusion	17
14. Annexes	18

1. Introduction

1.1 Contexte général

La cybersécurité est devenue un enjeu majeur pour les entreprises de toutes tailles. Face à l'augmentation exponentielle des cyberattaques (ransomwares, intrusions, vol de données), les organisations doivent se doter d'outils de supervision capables de détecter les menaces en temps réel et d'y répondre automatiquement.

Selon l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information), le nombre d'incidents traités a considérablement augmenté ces dernières années, touchant aussi bien les grands groupes que les PME et les startups.

1.2 Importance de la supervision et de la détection des intrusions

Un SIEM (Security Information and Event Management) est une solution qui centralise et analyse les événements de sécurité provenant de l'ensemble du système d'information. Il permet de :

- Collecter et corrélérer les logs de tous les équipements du réseau
- Détecter les comportements anormaux et les tentatives d'intrusion
- Générer des alertes classées par niveau de sévérité
- Répondre automatiquement aux incidents (Active Response)
- Assurer la traçabilité des événements pour des audits de sécurité

Un XDR (Extended Detection and Response) va encore plus loin en intégrant la détection à plusieurs couches : endpoints, réseau, cloud et applications.

1.3 Objectif du document

Ce rapport présente le déploiement complet d'une solution Wazuh SIEM/XDR réalisé dans le cadre du projet E6 du BTS SIO SISR. Il décrit l'ensemble des étapes : installation, configuration, durcissement des systèmes, simulation d'attaque et réponse automatique aux incidents.

2. Présentation du projet

2.1 L'entreprise Securitech

Securitech est une ESN (Entreprise de Services du Numérique) spécialisée en cybersécurité, comptant 45 employés répartis entre une équipe SOC (Security Operations Center), des ingénieurs systèmes et réseaux, et un pôle développement. Elle accompagne ses clients dans la mise en place de solutions de sécurité adaptées à leurs besoins.

2.2 Le client : société CUB

La société CUB est un incubateur de startups basé à Montpellier. Elle héberge une vingtaine de jeunes entreprises dans ses locaux et met à leur disposition une infrastructure informatique partagée. Avec la croissance de son parc et l'hébergement de données sensibles liées aux startups résidentes, CUB a sollicité Securitech pour renforcer sa posture sécurité.

2.3 Problématique

Comment détecter efficacement les tentatives d'intrusion et les comportements anormaux sur l'infrastructure de CUB, et comment répondre automatiquement aux menaces identifiées sans intervention humaine immédiate ?

2.4 Objectifs du projet

1. Déployer un serveur Wazuh SIEM/XDR sur l'infrastructure Proxmox de CUB
2. Installer et configurer des agents sur les endpoints (Linux et Windows)
3. Réaliser un durcissement CIS Benchmark des systèmes surveillés
4. Simuler une attaque brute force SSH pour valider la détection
5. Configurer l'Active Response pour bloquer automatiquement les attaquants

2.5 Résultats attendus

- Supervision en temps réel de 2 endpoints (Linux + Windows)
- Score SCA amélioré sur les deux machines
- Détection automatique d'une attaque brute force SSH

- Blocage automatique de l'IP attaquante par firewall
-

3. Pourquoi avoir choisi Wazuh ?

3.1 Présentation de Wazuh

Wazuh est une plateforme de sécurité open source qui combine les fonctionnalités d'un SIEM et d'un XDR. Initialement basé sur OSSEC (Open Source HIDS), il a évolué pour devenir une solution complète intégrant :

- Un manager central qui reçoit et analyse les événements
- Un indexer basé sur OpenSearch pour le stockage et la recherche
- Un dashboard web pour la visualisation
- Des agents légers déployés sur les machines surveillées

3.2 Comparaison avec d'autres solutions

Solution	Type	Coût	Complexité	Points forts
Wazuh	SIEM/XDR Open Source	Gratuit	Moyenne	Complet, communauté active, MITRE ATT&CK
Splunk	SIEM Commercial	Très élevé	Élevée	Très puissant, grande échelle
OSSEC	HIDS Open Source	Gratuit	Faible	Léger, mais limité sans dashboard
ELK Stack	SIEM Custom	Gratuit/Payant	Très élevée	Flexible mais demande expertise
IBM QRadar	SIEM Commercial	Élevé	Élevée	Enterprise, certifié ANSSI

3.3 Avantages de Wazuh dans un contexte pédagogique

- 100% open source et gratuit, idéal pour un projet étudiant
- Documentation officielle complète et communauté très active
- Intégration native du framework MITRE ATT&CK
- Module SCA (Security Configuration Assessment) pour le hardening CIS
- Active Response pour automatiser la réponse aux incidents
- Dashboard web intuitif basé sur OpenSearch/Kibana
- Support multi-OS : Linux, Windows, macOS

4. Présentation de l'infrastructure

4.1 Architecture générale

Le projet est déployé sur un hyperviseur Proxmox VE accessible dans le réseau de l'école (10.3.0.0/16, passerelle 10.3.0.254). Toutes les machines virtuelles sont connectées sur le bridge vmbr0 (IP Proxmox : 10.3.0.253/16).

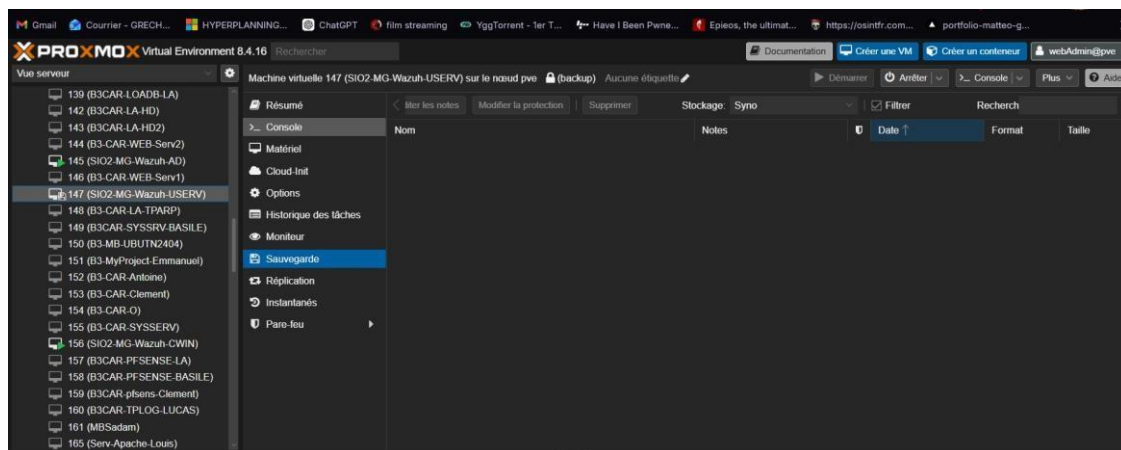


Fig. 1 – Vue Proxmox – VM 147 (SIO2-MG-Wazuh-USERV) avec les autres VMs du projet

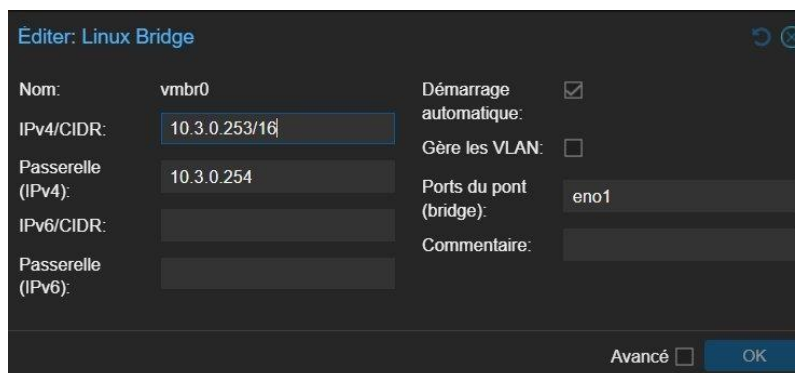


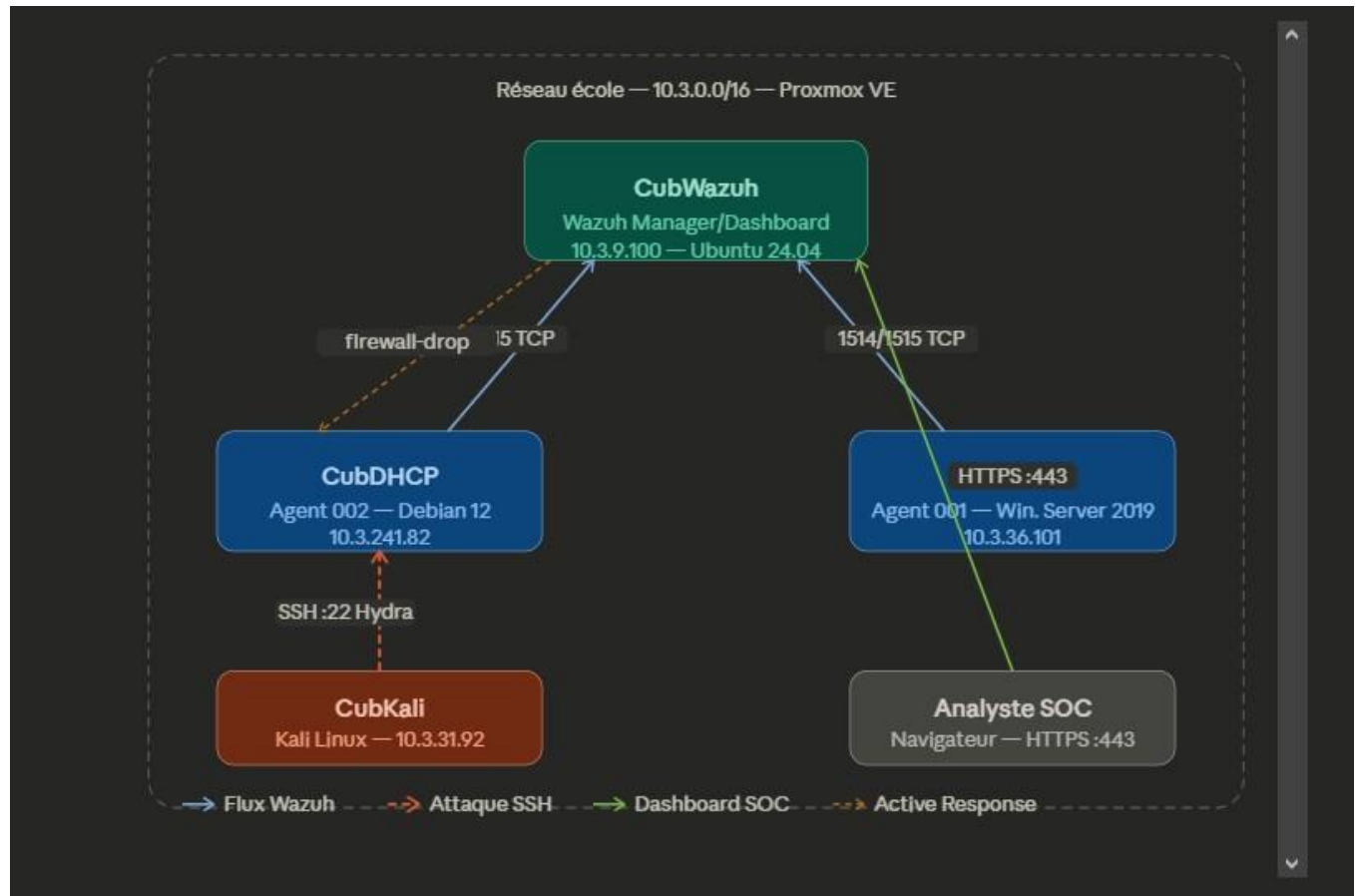
Fig. 2 – Configuration réseau Proxmox – Bridge vmbr0 sur 10.3.0.253/16

4.2 Tableau des machines virtuelles

VM	OS	IP	Rôle	Agent Wazuh
CubWazuh	Ubuntu Server 24.04	10.3.9.100/16	Serveur Wazuh (Manager + Indexer + Dashboard)	Manager
CubDHCP	Debian 12	10.3.241.82/16	Serveur DHCP	Agent ID 002
CubAD	Windows Server 2019	10.3.36.101/16	Active Directory (Contrôleur de domaine)	Agent ID 001
CubKali	Kali Linux	10.3.31.92/16	Machine attaquante (tests de pénétration)	Aucun

4.3 Schéma d'architecture

Le schéma ci-dessous illustre les flux de communication entre les composants :



5. Prérequis techniques

5.1 Configuration minimale du serveur Wazuh

Composant	Minimum	Configuration utilisée
Processeur	2 vCPU	4 vCPU
RAM	4 Go	8 Go
Disque	50 Go	60 Go (SSD)
OS	Ubuntu 20.04+	Ubuntu Server 24.04 LTS
Réseau	1 interface	vmbr0 (10.3.9.100/16)

5.2 Ports réseau nécessaires

Port	Protocole	Usage
443	TCP	Accès au Dashboard Wazuh (HTTPS)
1514	TCP/UDP	Communication agents → manager
1515	TCP	Enregistrement des agents
9200	TCP	API OpenSearch (interne)
55000	TCP	API REST Wazuh

5.3 Logiciels nécessaires

- Proxmox VE 8.x – hyperviseur
- Wazuh 4.11 – SIEM/XDR (manager + indexer + dashboard)
- Filebeat – pipeline d’envoi des alertes vers OpenSearch
- rsyslog – gestion des logs système sur Debian
- UFW – pare-feu Linux
- Hydra – outil de test brute force (depuis Kali Linux)

6. Installation de Wazuh

6.1 Installation du serveur (CubWazuh)

L’installation du serveur Wazuh est réalisée via le script officiel de Wazuh qui installe et configure automatiquement les 4 composants : Manager, Indexer (OpenSearch), Dashboard et Filebeat.

Commandes d’installation :

```
curl -sO https://packages.wazuh.com/4.11/wazuh-install.sh
curl -sO https://packages.wazuh.com/4.11/config.yml #
Éditer config.yml avec l'IP du serveur (10.3.9.100) sudo
bash wazuh-install.sh -a
```

Le script installe et démarre automatiquement tous les services. Une fois terminé, le dashboard est accessible à l’adresse <https://10.3.9.100> avec les identifiants générés automatiquement.

Vérification des services :

```
sudo systemctl status wazuh-manager sudo
systemctl status wazuh-indexer sudo
systemctl status wazuh-dashboard sudo
systemctl status filebeat
```

6.2 Installation de l'agent sur CubDHCP (Debian 12)

Sur la machine CubDHCP, l'agent Wazuh est installé et configuré pour pointer vers le manager :

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | gpg --dearmor >
/usr/share/keyrings/wazuh.gpg
echo 'deb [signed-by=/usr/share/keyrings/wazuh.gpg]
https://packages.wazuh.com/4.x/apt/ stable main' >
/etc/apt/sources.list.d/wazuh.list apt-get
update && apt-get install wazuh-agent
WAZUH_MANAGER='10.3.9.100' systemctl start wazuh-agent systemctl
enable wazuh-agent
```

Important : Le pare-feu UFW doit autoriser les ports sortants 1514 et 1515 pour que l'agent puisse communiquer avec le manager :

```
sudo ufw allow out 1514/tcp sudo
ufw allow out 1515/tcp
```

6.3 Installation de l'agent sur CubAD (Windows Server 2019)

Sur CubAD, l'agent Wazuh est installé via le programme d'installation MSI téléchargé depuis le dashboard Wazuh. Une fois installé, il est démarré via PowerShell :

```
NET START WazuhSvc
```

```
PS C:\Users\Administrateur> NET START WazuhSvc
Le service Wazuh a démarré.

PS C:\Users\Administrateur> net accounts
Fermeture forcée de la session après expiration ? :          Jamais
Durée de vie minimale du mot de passe (jours) :             1
Durée de vie maximale du mot de passe (jours) :             365
Longueur minimale du mot de passe :                         14
Nombre de mots de passe antérieurs à conserver :             Aucune
Seuil de verrouillage :                                       5
Durée du verrouillage (min) :                                 15
Fenêtre d'observation du verrouillage (min) :                10
Rôle de l'ordinateur :                                         SERVEUR
La commande s'est terminée correctement.

PS C:\Users\Administrateur> █
```

Fig. 3 – Démarrage du service Wazuh sur CubAD via PowerShell

La confirmation « Le service Wazuh a démarré » indique que l'agent est opérationnel et connecté au manager.

7. Configuration de Wazuh

7.1 Configuration de la collecte des logs SSH

Sur Debian 12, le système utilise journald par défaut et ne génère pas de fichier /var/log/auth.log. Pour que Wazuh puisse analyser les logs SSH, il faut :

6. Installer rsyslog pour générer auth.log
7. Configurer le format de log en mode traditionnel (compatible Wazuh)
8. Ajouter la source de logs dans ossec.conf

```
sudo apt install rsyslog
# Dans /etc/rsyslog.conf, ajouter :
$ActionFileDefaultTemplate RSYSLOG_TraditionalFileFormat sudo systemctl
restart rsyslog
```

Dans /var/ossec/etc/ossec.conf, ajouter le bloc de surveillance :

```
<localfile>
  <log_format>syslog</log_format>
  <location>/var/log/auth.log</location>
</localfile>
sudo systemctl restart wazuh-agent
```

7.2 Configuration de Filebeat

Filebeat est responsable de l'envoi des alertes du manager vers l'indexer OpenSearch. Il était configuré par défaut pour pointer vers 127.0.0.1 (localhost), ce qui empêchait l'indexation des alertes. Correction dans /etc/filebeat/filebeat.yml :

```
output.elasticsearch.hosts:
- 10.3.9.100:9200
ssl.verification_mode: none
```

7.3 Vue du dashboard Wazuh

Une fois tous les agents connectés et Filebeat correctement configuré, le dashboard Wazuh affiche 2 agents actifs et les alertes en temps réel.

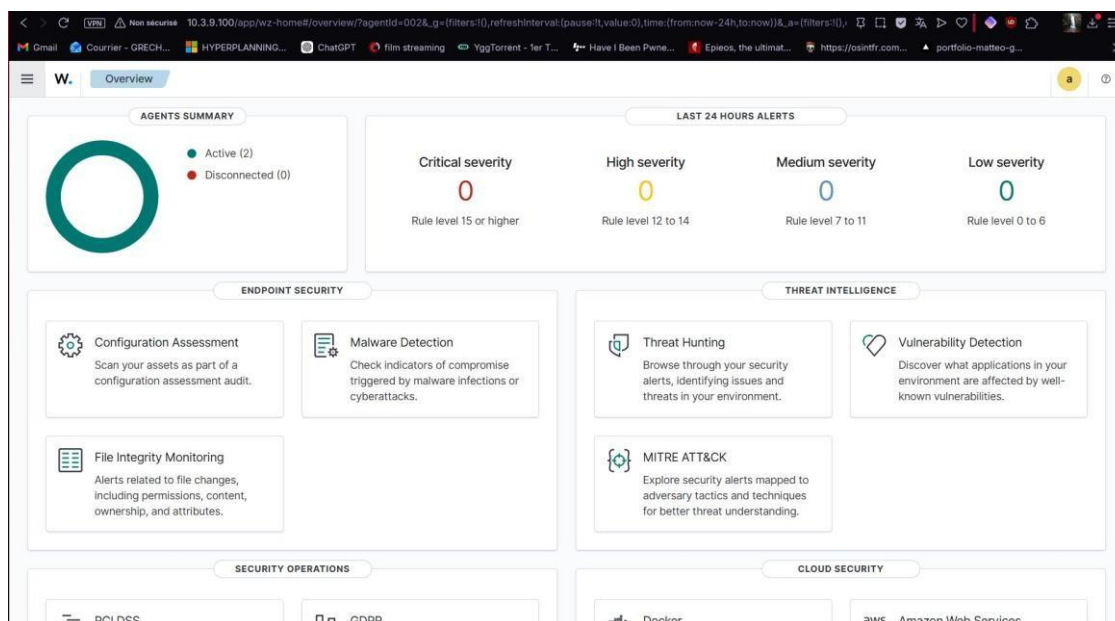


Fig. 4 – Dashboard Wazuh – Vue générale avec 2 agents actifs

Checks (273) [Refresh](#) [Export formatted](#)

result=failed [WQL](#)

ID ↑	Title	Target	Result
16500	Ensure 'Maximum password age' is set to '365 ...	Command: net.exe accounts	Failed
16501	Ensure 'Minimum password age' is set to '1 or ...	Command: net.exe accounts	Failed
16502	Ensure 'Minimum password length' is set to '14...	Command: net.exe accounts	Failed
16503	Ensure 'Account lockout duration' is set to '15 ...	Command: net.exe accounts	Failed
16504	Ensure 'Account lockout threshold' is set to '5 ...	Command: net.exe accounts	Failed
16505	Ensure 'Reset account lockout counter after' is...	Command: net.exe accounts	Failed
16506	Ensure 'Accounts: Block Microsoft accounts' is ...	Registry: HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System	Failed
16507	Ensure 'Accounts: Guest account status' is set ...	Command: net user guest	Failed
16509	Configure 'Accounts: Rename administrator ac...	Command: net user administrator	Failed
16510	Configure 'Accounts: Rename guest account'.	Command: net user guest	Failed

Rows per page: 10 [1](#) [2](#) [3](#) [4](#) [5](#) ... [28](#)

Fig. 5 – Vue détaillée de l'agent CubDHCP – Modules disponibles

8. Durcissement SCA (Security Configuration Assessment)

8.1 Principe du SCA

Le module SCA de Wazuh évalue la conformité de la configuration d'un système par rapport aux référentiels CIS Benchmark (Center for Internet Security). Il attribue un score en

pourcentage selon le nombre de contrôles passés. L'objectif n'est pas d'atteindre 100%, mais de démontrer une démarche structurée d'amélioration de la sécurité.

Le scan SCA est exécuté automatiquement au démarrage de l'agent puis toutes les 12 heures. On peut le forcer manuellement :

```
sudo /var/ossec/bin/agent_control -r -u 002
```

8.2 Durcissement de CubDHCP (Debian 12)

Score initial : 27%

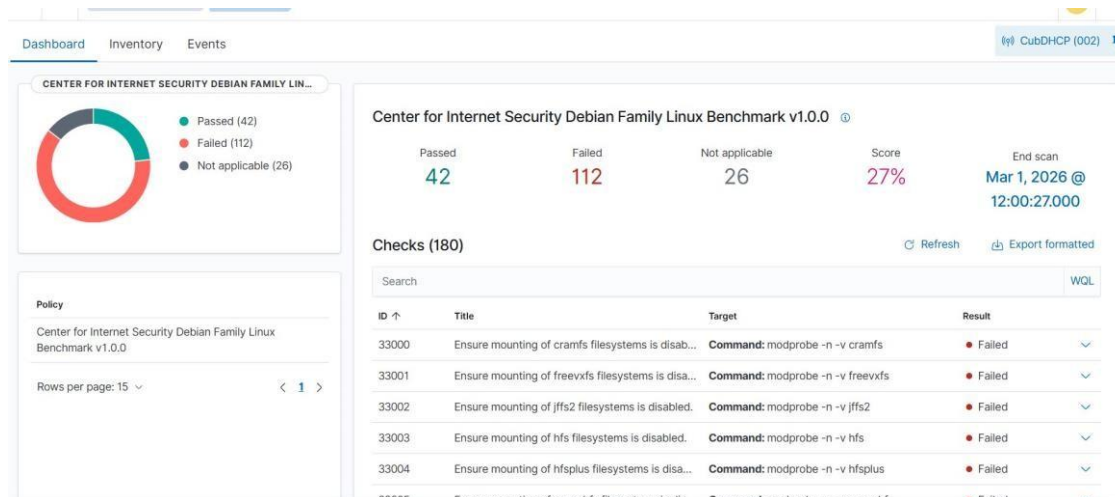


Fig. 6 – Score SCA initial CubDHCP : 27% (42 passés / 112 échoués – 1er mars 2026)

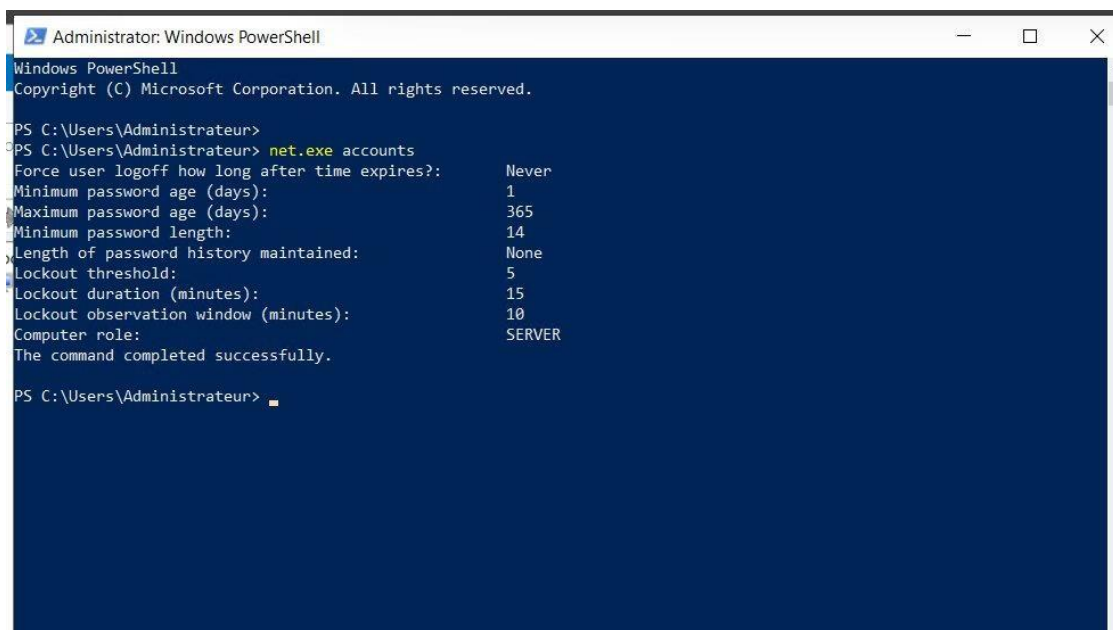
Actions de remédiation réalisées

Les mesures de durcissement suivantes ont été appliquées :

- Désactivation des systèmes de fichiers inutiles (cramfs, jffs2, hfs, hfsplus, squashfs, udf, usb-storage) via /etc/modprobe.d/
- Désactivation des protocoles réseau non utilisés (bluetooth, dccp, sctp, rds, tipc)
- Correction des permissions sur /boot/grub/grub.cfg, /etc/issue, /etc/issue.net, /etc/motd
- Configuration des bannières de connexion : « Authorized uses only. All activity may be monitored and reported. »
- Suppression des services inutiles : avahi-daemon, cups
- Montage de /dev/shm avec l'option noexec (ajout dans /etc/fstab)
- Activation de la journalisation sudo via /etc/sudoers.d/sudo_log
- Activation d'AppArmor dans le bootloader GRUB
- Activation d'UFW avec ouverture des ports nécessaires uniquement Exemple de commandes de durcissement :

```
echo 'install cramfs /bin/false' >> /etc/modprobe.d/disable-fs.conf
chmod 600 /boot/grub/grub.cfg
echo 'Defaults logfile=/var/log/sudo.log' >> /etc/sudoers.d/sudo_log sudo
ufw --force enable && sudo ufw allow 22/tcp
```

Score intermédiaire : 30%



```

Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\Administrateur> net.exe accounts
Force user logoff how long after time expires?: Never
Minimum password age (days): 1
Maximum password age (days): 365
Minimum password length: 14
Length of password history maintained: None
Lockout threshold: 5
Lockout duration (minutes): 15
Lockout observation window (minutes): 10
Computer role: SERVER
The command completed successfully.

PS C:\Users\Administrateur>

```

Fig. 7 – Score SCA CubDHCP après premières remédiations : 30% (7 mars 2026)

Score final : 38%

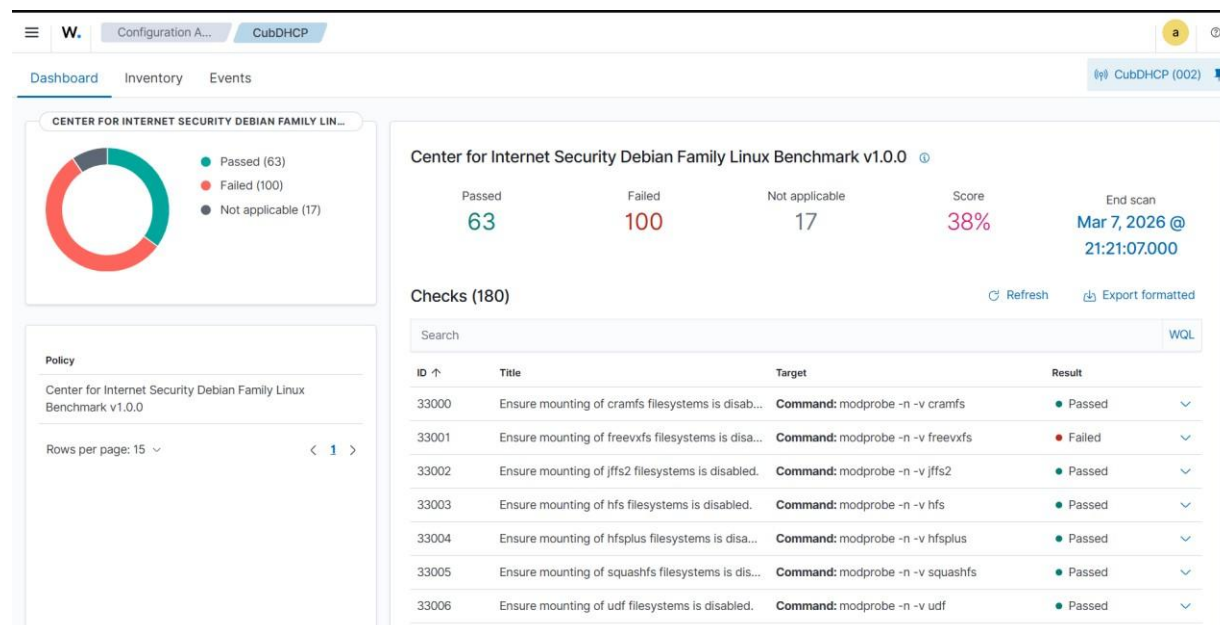


Fig. 8 – Score SCA final CubDHCP : 38% (63 passés – 7 mars 2026 à 21h21)

La progression de 27% à 38% représente 11 points gagnés et 21 nouveaux contrôles conformes. Note : Le contrôle 33001 (freevxfs) reste en échec malgré la configuration correcte – bug connu de Wazuh 4.11.

8.3 Durcissement de CubAD (Windows Server 2019)

Sur CubAD, la principale action de durcissement concerne la politique de mots de passe, configurée via la Stratégie de Sécurité Locale (secpol.msc) :

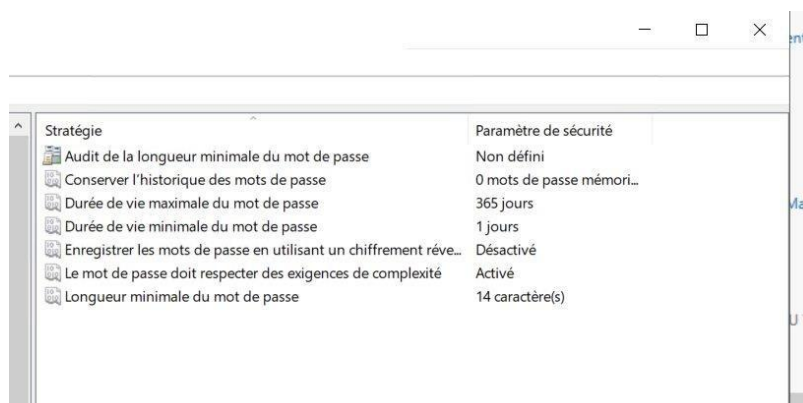


Fig. 9 – Politique de mots de passe Windows (longueur min. 14, complexité activée)

```
PS C:\Users\Administrateur> NET START WazuhSvc
Le service Wazuh a démarré.

PS C:\Users\Administrateur> net accounts
Fermeture forcée de la session après expiration ? :          Jamais
Durée de vie minimale du mot de passe (jours) :             1
Durée de vie maximale du mot de passe (jours) :             365
Longueur minimale du mot de passe :                         14
Nombre de mots de passe antérieurs à conserver :             Aucune
Seuil de verrouillage :                                      5
Durée du verrouillage (min) :                                15
Fenêtre d'observation du verrouillage (min) :                10
Rôle de l'ordinateur :                                       SERVEUR
La commande s'est terminée correctement.

PS C:\Users\Administrateur> net.exe accounts
Fermeture forcée de la session après expiration ? :          Jamais
Durée de vie minimale du mot de passe (jours) :             1
Durée de vie maximale du mot de passe (jours) :             365
Longueur minimale du mot de passe :                         14
Nombre de mots de passe antérieurs à conserver :             Aucune
Seuil de verrouillage :                                      5
Durée du verrouillage (min) :                                15
Fenêtre d'observation du verrouillage (min) :                10
Rôle de l'ordinateur :                                       SERVEUR
La commande s'est terminée correctement.

PS C:\Users\Administrateur>
```

Fig. 10 – Vérification PowerShell – Seuil de verrouillage : 5 tentatives, durée : 15 min

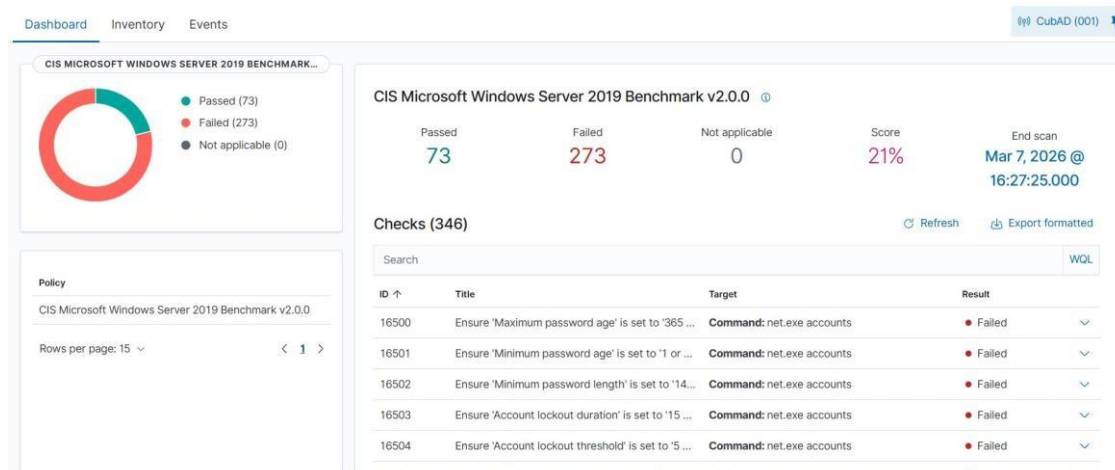


Fig. 11 – Score SCA CubAD : 21% (73 passés sur 346 – CIS Windows Server 2019 Benchmark)

9. Tests réalisés – Attaque brute force SSH

9.1 Présentation du scénario

Pour valider la chaîne de détection de Wazuh, une attaque de type brute force SSH a été simulée depuis CubKali (10.3.31.92) vers CubDHCP (10.3.241.82). Ce type d'attaque correspond à la technique MITRE ATT&CK T1110.001 (Brute Force: Password Guessing) sous la tactique Credential Access.

L'outil utilisé est Hydra, un outil open source de test d'authentification par force brute. Il teste des milliers de combinaisons login/mot de passe depuis un dictionnaire (rockyou.txt).

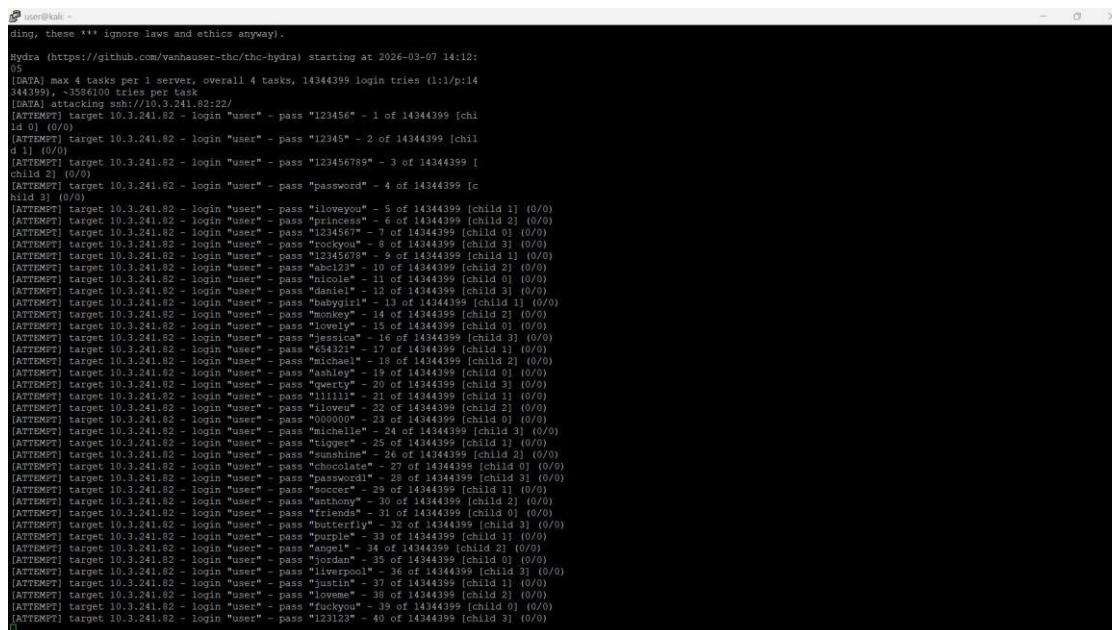
9.2 Lancement de l'attaque

Commande exécutée depuis CubKali :

```
# Décompression du dictionnaire sudo gunzip
/usr/share/wordlists/rockyou.txt.gz

# Lancement de l'attaque brute force SSH
hydra -l user -P /usr/share/wordlists/rockyou.txt ssh://10.3.241.82 -t 4 -V
```

Paramètres utilisés : -l user (login cible), -P rockyou.txt (dictionnaire de 14 344 399 mots de passe), -t 4 (4 threads parallèles), -V (mode verbose).



```
ding, these *** ignore laws and ethics anyway! -
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-07 14:12:
05
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (1:1/p:14
344399), ~3584100 tries per task
[DATA] attacking ssh://10.3.241.82:22/
[ATTEMPT] target 10.3.241.82 - login "user" - pass "123456" - 1 of 14344399 [chil
d 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "12345" - 2 of 14344399 [chil
d 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "123456789" - 3 of 14344399 [
child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "password" - 4 of 14344399 [c
hild 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "iloveyou" - 5 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "princess" - 6 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "1234567" - 7 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "rockyou" - 8 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "12345678" - 9 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "abc123" - 10 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "nicole" - 11 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "daniel" - 12 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "babygirl" - 13 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "monkey" - 14 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "lowly" - 15 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "jessica" - 16 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "654321" - 17 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "michael" - 18 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "ashley" - 19 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "querty" - 20 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "111111" - 21 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "ilove" - 22 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "000000" - 23 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "michelle" - 24 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "tiger" - 25 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "sunshine" - 26 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "chocolate" - 27 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "password1" - 28 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "soccer" - 29 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "anthony" - 30 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "friends" - 31 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "butterfly" - 32 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "purple" - 33 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "angel" - 34 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "jordan" - 35 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "liverpool" - 36 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "justin" - 37 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "loves" - 38 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "fuckyou" - 39 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.3.241.82 - login "user" - pass "123123" - 40 of 14344399 [child 3] (0/0)
```

Fig. 12 – Lancement de Hydra depuis CubKali – Attaque brute force SSH sur 10.3.241.82


```

mars 07 20:16:35 debian sshd[42437]: Failed password for user from 10.3.31.92 po
rt 45164 ssh2
mars 07 20:16:35 debian sshd[42431]: Failed password for user from 10.3.31.92 po
rt 45140 ssh2
mars 07 20:16:35 debian sshd[42432]: Failed password for user from 10.3.31.92 po
rt 45144 ssh2
mars 07 20:16:37 debian sshd[42435]: Failed password for user from 10.3.31.92 po
rt 45160 ssh2
mars 07 20:16:37 debian sshd[42437]: Failed password for user from 10.3.31.92 po
rt 45164 ssh2
mars 07 20:16:37 debian sshd[42431]: Failed password for user from 10.3.31.92 po
rt 45140 ssh2
mars 07 20:16:37 debian sshd[42432]: Failed password for user from 10.3.31.92 po
rt 45144 ssh2
mars 07 20:16:39 debian sshd[42435]: Failed password for user from 10.3.31.92 po
rt 45160 ssh2
mars 07 20:16:39 debian sshd[42437]: Failed password for user from 10.3.31.92 po
rt 45164 ssh2
mars 07 20:16:39 debian sshd[42431]: Failed password for user from 10.3.31.92 po
rt 45140 ssh2
mars 07 20:16:39 debian sshd[42432]: Failed password for user from 10.3.31.92 po
rt 45144 ssh2
mars 07 20:16:42 debian sshd[42435]: Failed password for user from 10.3.31.92 po
rt 45160 ssh2
mars 07 20:16:42 debian sshd[42437]: Failed password for user from 10.3.31.92 po
rt 45164 ssh2
mars 07 20:16:42 debian sshd[42431]: Failed password for user from 10.3.31.92 po
rt 45140 ssh2
mars 07 20:16:42 debian sshd[42432]: Failed password for user from 10.3.31.92 po
rt 45144 ssh2
mars 07 20:16:42 debian sshd[42431]: error: maximum authentication attempts exce
eded for user from 10.3.31.92 port 45140 ssh2 [preauth]
mars 07 20:16:42 debian sshd[42431]: Disconnecting authenticating user user 10.3
.31.92 port 45140: Too many authentication failures (preauth)
mars 07 20:16:42 debian sshd[42431]: PAM 5 more authentication failures; logname
= uid=0 euid=0 tty=ssh ruser= rhost=10.3.31.92 user=user
mars 07 20:16:42 debian sshd[42431]: PAM service(sshd) ignoring max retries: 6 >
3
mars 07 20:16:42 debian sshd[42432]: error: maximum authentication attempts exce
eded for user from 10.3.31.92 port 45144 ssh2 [preauth]
mars 07 20:16:42 debian sshd[42432]: Disconnecting authenticating user user 10.3
.31.92 port 45144: Too many authentication failures (preauth)
mars 07 20:16:42 debian sshd[42432]: PAM 5 more authentication failures; logname
= uid=0 euid=0 tty=ssh ruser= rhost=10.3.31.92 user=user
mars 07 20:16:42 debian sshd[42432]: PAM service(sshd) ignoring max retries: 6 >
3
mars 07 20:16:42 debian sshd[42433]: pam_unix(sshd:auth): authentication failure
; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.3.31.92 user=user
mars 07 20:16:42 debian sshd[42434]: pam_unix(sshd:auth): authentication failure
; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.3.31.92 user=user
^C
user@debian:~$

```

Fig. 13 – Hydra en cours d'exécution (≈66 tentatives/min, 14,3M de mots de passe)

9.3 Logs SSH sur CubDHCP

L'attaque est visible en temps réel dans les logs SSH de CubDHCP. On observe des centaines de « Failed password » et « maximum authentication attempts exceeded » :

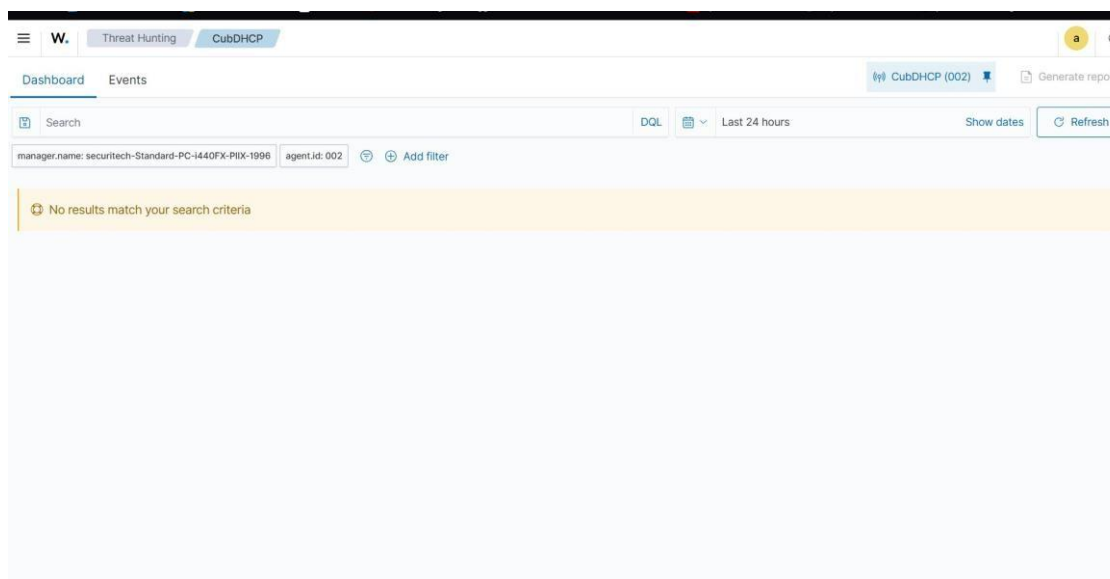


Fig. 14 – Logs SSH de CubDHCP – Tentatives échouées de 10.3.31.92 (CubKali)

9.4 Framework MITRE ATT&CK avant l'attaque

Avant le lancement de l'attaque, le framework MITRE ATT&CK dans Wazuh affiche 0 alerte pour toutes les techniques, confirmant un état initial propre :

The screenshot displays the Wazuh Framework MITRE ATT&CK interface. The top navigation bar includes 'Dashboard', 'Intelligence', 'Framework', and 'Events'. The 'Framework' tab is selected, showing a search bar and filters for 'manager.name: securitech-Standard-PC-i440FX-PIIX-1996', 'rule.mitre.id: exists', and 'agent.id: 002'. The left sidebar lists Tactics: Credential Access, Execution, Impact, Persistence, Privilege Escalation, Lateral Movement, Defense Evasion, Exfiltration, Discovery, and Collection. The main area shows Techniques, with a search bar and a table of techniques. All techniques are marked with a '0' icon, indicating they are not yet active or detected.

Tactics	Techniques
Credential Access	T1557 - Adversary-in-the-Middle, T1556.003 - Pluggable Authentication...
Execution	T1056.001 - Keylogging, T1110.001 - Password Guessing
Impact	T1003 - OS Credential Dumping, T1171 - LLMNR/NBT-NS Poisoning a...
Persistence	T1539 - Steal Web Session Cookie, T1003.002 - Security Account Man...
Privilege Escalation	T1552.005 - Cloud Instance Metad..., T1555.002 - Securityd Memory
Lateral Movement	T1522 - Cloud Instance Metadata API, T1110.002 - Password Cracking
Defense Evasion	T1555.001 - Keychain, T1003.004 - LSA Secrets
Exfiltration	T1606.002 - SAML Tokens, T1167 - Securityd Memory
Discovery	T1040 - Network Sniffing, T1555.005 - Password Managers
Collection	T1040 - Network Sniffing, T1555.005 - Password Managers

Fig. 15 – Framework MITRE ATT&CK – Toutes les techniques à 0 avant l'attaque

10. Résultats obtenus

10.1 Détection en temps réel

Après correction de la configuration Filebeat (mauvaise IP) et du format rsyslog, Wazuh a détecté l'attaque en temps réel. Le dashboard affiche :

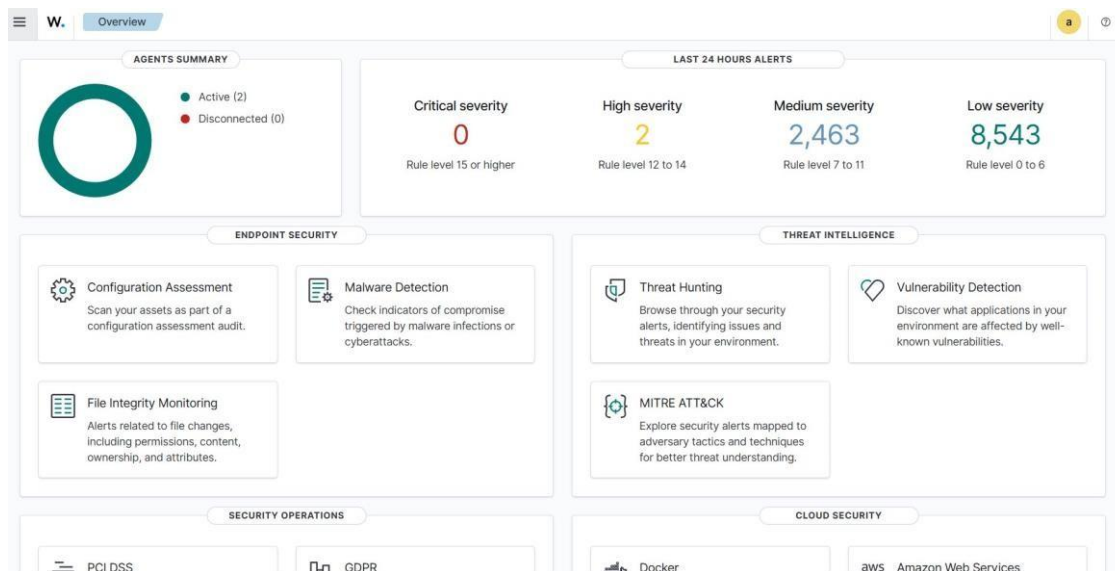


Fig. 16 – Dashboard Wazuh – 2 High, 2 463 Medium, 8 543 Low alerts en 24h

10.2 Détail des alertes (Threat Hunting)

Dans la vue Threat Hunting de CubDHCP, 274 alertes sont générées en 1 minute. Les règles déclenchées sont :

Règle ID	Niveau	Description	Signification
5760	5 (Low)	sshd: authentication failed	Chaque tentative Hydra
5503	5 (Low)	PAM: User login failed	Échec d'auth PAM
2502	10 (Medium)	User missed the password more than one time	Pattern brute force détecté
5758	8 (Medium)	Maximum authentication attempts exceeded	Seuil dépassé
651	3	Host Blocked by firewall-drop Active Response	IP bloquée automatiquement

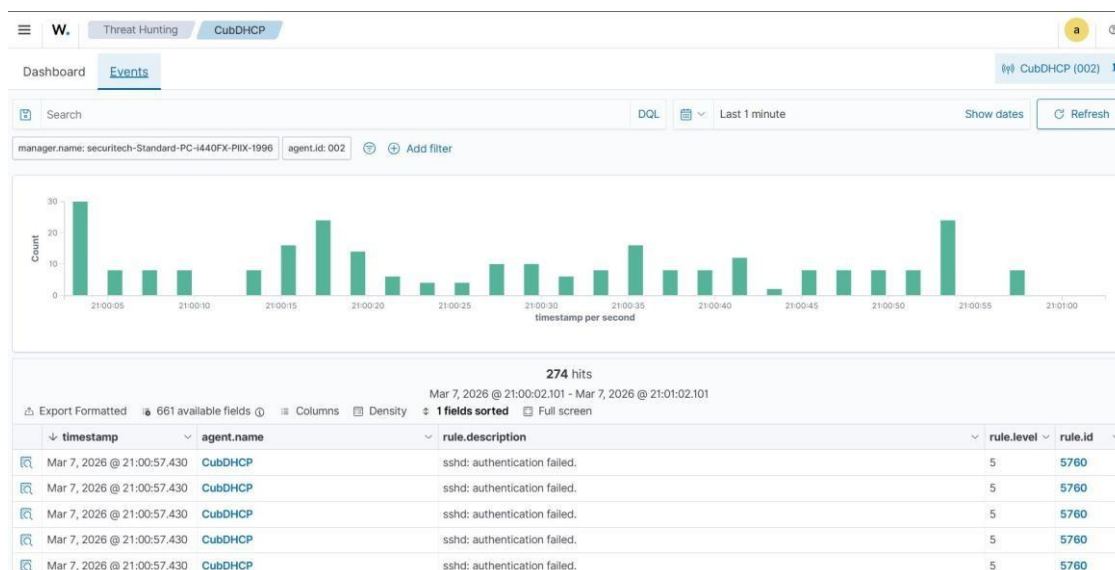


Fig. 17 – Threat Hunting – 274 alertes en 1 minute, règle 5760 sshd: authentication failed

The screenshot shows a detailed view of the Wazuh Threat Hunting interface. It displays a list of events for rule 5760, 'sshd: authentication failed.', and rule 2502, 'syslog: User missed the password more than one time'. The table columns are timestamp, agent.name, rule.description, rule.level, and rule.id.

timestamp	agent.name	rule.description	rule.level	rule.id
Mar 7, 2026 @ 21:00:57.430	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:57.430	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:57.430	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:57.430	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:57.430	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:57.430	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:57.430	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:57.389	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:53.439	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:53.437	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:53.435	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:53.433	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:00:53.431	CubDHCP	PAM: User login failed.	5	5503
Mar 7, 2026 @ 21:00:53.429	CubDHCP	PAM: User login failed.	5	5503
Mar 7, 2026 @ 21:00:53.425	CubDHCP	syslog: User missed the password more than one time	10	2502

Fig.

18 – Détail des règles – Escalade de niveau 5 à 10, détection du pattern brute force

10.3 Active Response – Blocage automatique de l'IP attaquante

L'Active Response est configurée dans `/var/ossec/etc/ossec.conf` sur le manager. Lorsque la règle 2502 se déclenche (brute force détecté), Wazuh exécute automatiquement le script `firewall-drop` qui ajoute une règle iptables pour bloquer l'IP attaquante pendant 180 secondes :

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>2502</rules_id>
  <timeout>180</timeout>
</active-response>
```

Pour bloquer manuellement une IP de manière temporaire (commande iptables sur CubDHCP) :

```
sudo iptables -A INPUT -s 10.3.31.92 -j DROP    # Bloquer sudo
iptables -D INPUT -s 10.3.31.92 -j DROP    # Débloquer sudo
iptables -L INPUT -n --line-numbers        # Vérifier
```

Le résultat visible dans le Threat Hunting montre les alertes « Host Blocked by firewall-drop Active Response » (règle 651) intercalées avec les tentatives d'authentification :

timestamp	agent.name	rule.description	rule.level	rule.id
Mar 7, 2026 @ 21:37:39.684	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:37:39.684	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:37:37.761	CubDHCP	Host Blocked by firewall-drop Active Response	3	651
Mar 7, 2026 @ 21:37:37.748	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:37:37.748	CubDHCP	Host Blocked by firewall-drop Active Response	3	651
Mar 7, 2026 @ 21:37:37.735	CubDHCP	Host Blocked by firewall-drop Active Response	3	651
Mar 7, 2026 @ 21:37:37.714	CubDHCP	Host Blocked by firewall-drop Active Response	3	651
Mar 7, 2026 @ 21:37:37.701	CubDHCP	sshd: authentication failed.	5	5760
Mar 7, 2026 @ 21:37:37.701	CubDHCP	Host Blocked by firewall-drop Active Response	3	651
Mar 7, 2026 @ 21:37:37.689	CubDHCP	Host Blocked by firewall-drop Active Response	3	651
Mar 7, 2026 @ 21:37:35.743	CubDHCP	syslog: User authentication failure.	5	2501
Mar 7, 2026 @ 21:37:35.743	CubDHCP	syslog: User missed the password more than one time	10	2502
Mar 7, 2026 @ 21:37:35.743	CubDHCP	PAM: User login failed.	5	5503
Mar 7, 2026 @ 21:37:35.743	CubDHCP	Maximum authentication attempts exceeded.	8	5758
Mar 7, 2026 @ 21:37:35.743	CubDHCP	syslog: User authentication failure.	5	2501

Fig. 19 – 17 104 alertes – Blocage automatique de 10.3.31.92 par firewall-drop (règle 651)

Le cycle complet est ainsi démontré : attaque détectée → règle 2502 déclenchée → IP bloquée automatiquement pendant 3 minutes → alerte règle 651 visible dans le dashboard.

11. Difficultés rencontrées

Difficulté	Cause	Solution apportée
UFW bloquait SSH au démarrage	Activation d'UFW sans règle SSH	<code>sudo ufw allow 22/tcp</code> avant activation
Ports 1514/1515 bloqués (UFW)	UFW bloquait les ports sortants Wazuh	<code>sudo ufw allow out 1514/tcp && 1515/tcp</code>
auth.log absent sur Debian 12	Debian 12 utilise journald par défaut	Installation et configuration de rsyslog
Format de logs incompatible	rsyslog utilisait le format ISO 8601	<code>\$ActionFileDefaultTemplate</code> <code>RSYSLOG_TraditionalFileFormat</code>
Filebeat ne se connectait pas	IP configurée sur 127.0.0.1 au lieu de 10.3.9.100	Correction dans <code>/etc/filebeat/filebeat.yml</code>
Erreur certificat SSL Filebeat	Certificat TLS valide pour 127.0.0.1 uniquement	<code>ssl.verification_mode: none</code> dans <code>filebeat.yml</code>
Pas d'index OpenSearch (1er mars)	Disque plein sur CubWazuh (no space left on device)	Libération espace disque + redémarrage Filebeat
33001 freevxfs toujours échoué	Bug connu de Wazuh 4.11 sur ce contrôle	Documenté pour le jury – non bloquant
Wazuh-manager ne démarre plus	Erreur de syntaxe XML dans <code>ossec.conf</code>	Vérification avec <code>journalctl -xeu wazuh-manager</code>

Ces difficultés illustrent le travail réel d'un administrateur système et réseau en entreprise : diagnostiquer les pannes, comprendre les logs d'erreur et trouver des solutions adaptées.

12. Documentation utilisée

- Documentation officielle Wazuh :
<https://documentation.wazuh.com/current/> • CIS Benchmark Debian 12 : https://www.cisecurity.org/benchmark/debian_linux
- CIS Benchmark Windows Server 2019 :
https://www.cisecurity.org/benchmark/microsoft_windows_server

- MITRE ATT&CK Framework : <https://attack.mitre.org/>
- Documentation Proxmox VE : <https://pve.proxmox.com/wiki/>
- Documentation Hydra (THC) : <https://github.com/vanhauser-thc/thc-hydra>
- Documentation UFW (Uncomplicated Firewall) : `man ufw`
- Documentation rsyslog : <https://www.rsyslog.com/doc/>
- ANSSI – Guide d'hygiène informatique : <https://www.ssi.gouv.fr/>

13. Conclusion

13.1 Bilan du projet

Ce projet a permis de déployer une solution SIEM/XDR complète et fonctionnelle sur l'infrastructure de CUB. Wazuh s'est avéré être un outil puissant et polyvalent, couvrant à la fois la supervision de la configuration (SCA), la détection des menaces en temps réel et la réponse automatique aux incidents.

La simulation d'une attaque brute force SSH avec Hydra a validé l'ensemble de la chaîne : collecte des logs SSH via rsyslog, analyse par les règles Wazuh, génération de 17 104 alertes et blocage automatique de l'IP attaquante par firewall-drop. Le cycle complet détection-réponse est démontré en conditions réelles.

13.2 Compétences acquises

- Administration système Linux (Debian/Ubuntu) et Windows Server 2019
- Virtualisation avec Proxmox VE
- Déploiement et configuration d'une solution SIEM/XDR (Wazuh)
- Durcissement système selon les référentiels CIS Benchmark
- Analyse de logs et détection d'intrusion
- Pentest basique (Hydra, brute force SSH)
- Firewall Linux (UFW, iptables) et pare-feu Windows
- Compréhension du framework MITRE ATT&CK

13.3 Améliorations possibles

- Déployer Wazuh en haute disponibilité (cluster Indexer)
- Ajouter un agent sur un client Windows pour surveiller les postes utilisateurs
- Intégrer des alertes par email ou via webhook (Slack, Teams)
- Mettre en place des tableaux de bord PCI-DSS ou GDPR
- Améliorer les scores SCA en traitant les contrôles de partitionnement
- Déployer Fail2Ban en complément de l'Active Response Wazuh

14. Annexes

14.1 Commandes importantes

Commande	Description
----------	-------------

<code>sudo systemctl status wazuh-manager</code>	Vérifier l'état du manager
<code>sudo systemctl restart wazuh-agent</code>	Redémarrer l'agent
<code>sudo tail -f /var/ossec/logs/ossec.log</code>	Surveiller les logs de l'agent
<code>sudo /var/ossec/bin/agent_control -r -u 002</code>	Forcer un rescan SCA de l'agent 002
<code>sudo ufw status</code>	Vérifier l'état du pare-feu UFW
<code>sudo iptables -L INPUT -n --line-numbers</code>	Lister les règles iptables actives
<code>curl -k -u admin:PASS https://10.3.9.100:9200/_cat/indices</code>	Vérifier les index OpenSearch
<code>sudo journalctl -xeu wazuh-manager</code>	Déboguer le manager Wazuh
<code>sudo tail -f /var/log/auth.log</code>	Surveiller les logs SSH en temps réel

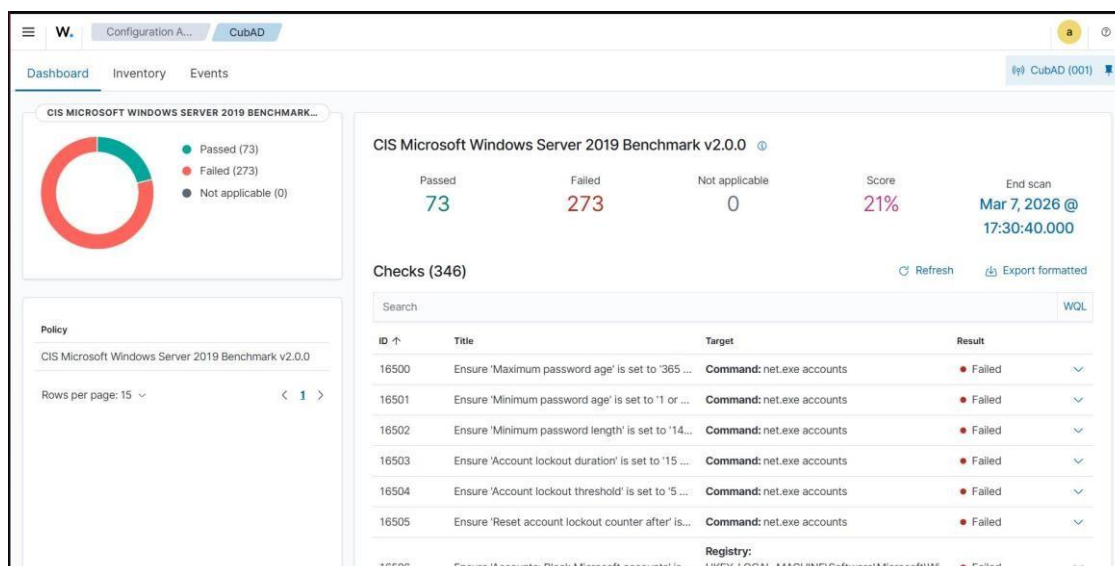
14.2 Captures d'écran supplémentaires

Checks (273) [Refresh](#) [Export formatted](#)

ID ↑	Title	Target	Result
16500	Ensure 'Maximum password age' is set to '365 ...	Command: net.exe accounts	Failed
16501	Ensure 'Minimum password age' is set to '1 or ...	Command: net.exe accounts	Failed
16502	Ensure 'Minimum password length' is set to '14...	Command: net.exe accounts	Failed
16503	Ensure 'Account lockout duration' is set to '15 ...	Command: net.exe accounts	Failed
16504	Ensure 'Account lockout threshold' is set to '5 ...	Command: net.exe accounts	Failed
16505	Ensure 'Reset account lockout counter after' is...	Command: net.exe accounts	Failed
16506	Ensure 'Accounts: Block Microsoft accounts' is ...	Registry: HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System	Failed
16507	Ensure 'Accounts: Guest account status' is set ...	Command: net user guest	Failed
16509	Configure 'Accounts: Rename administrator ac...	Command: net user administrator	Failed
16510	Configure 'Accounts: Rename guest account'.	Command: net user guest	Failed

Rows per page: 10 [1](#) [2](#) [3](#) [4](#) [5](#) ... [28](#)

Annexe 1 – Contrôles SCA échoués sur CubAD (filtrage result=failed)



Annexe 2 – Score SCA CubAD 21% (7 mars 2026)

```

écursé 10.3.0.253:8006

[FAILED] Failed to start gdm.service - GNOME Display Manager.
[FAILED] Failed to start gdm.service - GNOME Display Manager.
[FAILED] Failed to start wazuh-indexer.service - wazuh-indexer.
[FAILED] Failed to start gdm.service - GNOME Display Manager.
[FAILED] Failed to start gdm.service - GNOME Display Manager.
[FAILED] Failed to start gdm.service - GNOME Display Manager.
[FAILED] Failed to start plymouth-quit.service - Terminate Plymouth Boot Screen.
[FAILED] Failed to start wazuh-manager.service - Wazuh manager.

```

Annexe 3 – Erreurs de démarrage initiales sur la VM Wazuh (wazuh-indexer et gdm échoués)

14.3 Tableau récapitulatif des scores SCA

Machine	OS	Référentiel CIS	Score initial	Score final	Progression
CubDHCP	Debian 12	CIS Debian Family Linux Benchmark v1.0.0	27% (42/180)	38% (63/180)	+11 pts
CubAD	Windows Server 2019	CIS MS Windows Server 2019 Benchmark v2.0.0	21% (73/346)	21% (73/346)	Politique MDP